

### 1. Objet et portée

Cette politique définit l'approche de BantuDelice pour l'examen des **journaux d'audit d'administration** afin de détecter toute compromission ou utilisation abusive d'un compte administrateur sur l'environnement backend de production.

L'environnement concerné est le serveur VPS de production (*vps-0e8f1563.vps.ovh.net*) hébergeant l'application Laravel 10 BantuDelice, accessible via HTTPS. Le journal d'audit d'administration est produit par le **Linux Audit Framework (auditd 3.1.2)** avec 16 règles couvrant toutes les actions administratives sensibles.

### 2. Indicateurs de compromission ou d'abus surveillés

L'examen hebdomadaire couvre obligatoirement les quatre catégories d'indicateurs suivantes :

★ **CONDITIONS REQUISES — META APP REVIEW (SURLIGNÉES)**

- **Modèles de connexion d'administrateur inhabituels** : nouvelles adresses IP, connexions en dehors des plages horaires habituelles (hors 06:00–23:00 UTC), accumulation de tentatives d'authentification infructueuses SSH.
- **Modifications des contrôles d'accès susceptibles d'exposer les données de la plateforme à des utilisateurs non autorisés** : changements sur `/etc/sudoers`, `/etc/passwd`, `/etc/shadow`, ou les ACL des fichiers de configuration sensibles (`/opt/bantudelice/.env`).
- **Nouveaux comptes d'administrateur ou élévations de privilèges inattendues** : création de tout compte système (`useradd`, `usermod`, `passwd`), ajout au groupe `sudo` ou attribution de droits `root` non planifiée.
- **Modifications apportées aux configurations de journalisation, de surveillance ou de sécurité** : tout accès en écriture sur `/var/log/audit/`, `/var/log/auth.log`, `/var/log/fail2ban.log`, `/opt/bantudelice/storage/logs/`, ou tentative de désactivation d'`auditd/fail2ban`.

### 3. Fréquence et calendrier d'examen

★ **EXIGENCE DE FRÉQUENCE — META APP REVIEW (SURLIGNÉE)**

**Les journaux d'audit d'administration sont examinés au moins tous les 7 jours.** L'examen automatisé s'exécute chaque lundi à 08:00 UTC via cron planifié (`0 8 * * 1`), couvrant une période glissante de 7 jours. Cette fréquence garantit la conformité à l'exigence d'examen hebdomadaire de Meta.

En complément de l'examen hebdomadaire automatisé, **fail2ban** assure une surveillance continue 24h/24 des tentatives d'authentification SSH et bannit automatiquement les IP suspectes en temps réel.

### 4. Sources de journaux d'audit d'administration

| Journal                                    | Contenu                                                                                                               | Mode         |
|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|--------------|
| <code>/var/log/audit/audit.log</code>      | Toutes les commandes root ( <code>execve</code> ), modifications comptes, accès fichiers sensibles — 16 règles auditd | Temps réel   |
| <code>/var/log/auth.log</code>             | Authentifications SSH réussies et échouées, sessions sudo, changements PAM                                            | Temps réel   |
| <code>/var/log/fail2ban.log</code>         | IP bannies, compteurs d'échecs, événements jail sshd et sshd-permanent                                                | Temps réel   |
| <code>security-audit-YYYY-MM-DD.log</code> | Rapport d'analyse hebdomadaire agrégé — 4 catégories d'indicateurs + score SUMMARY                                    | Hebdomadaire |

### 5. Processus d'examen hebdomadaire

Le script `/opt/bantudelice/scripts/security-audit.sh` exécute automatiquement les analyses suivantes chaque lundi :

- **Indicateur 1 — Authentification anormale** : comptage des tentatives SSH échouées (`grep 'Failed password|Invalid user' /var/log/auth.log | wc -l`), identification des top IPs attaquantes, vérification du compteur fail2ban.
- **Indicateur 2 — Contrôles d'accès** : analyse des réponses HTTP 401/403/404 dans `/var/log/nginx/access.log` pour détecter des tentatives d'accès à des ressources protégées.
- **Indicateur 3 — Élévations et modifications** : recherche de commandes sensibles dans `/var/log/audit/audit.log` via les clés auditd (`useradd`, `usermod`, `chmod`, `chown`, `visudo`).
- **Indicateur 4 — Modifications de configuration de sécurité** : détection de toute écriture sur les journaux surveillés par auditd (clé `audit_log_access`, `auth_log_access`).

Le rapport produit est classé automatiquement : **LOW** (normal), **MODERATE** (surveillance renforcée), ou **REVIEW**

**RECOMMENDED** (investigation immédiate requise).

6. Procédure d'escalade

- Statut **REVIEW RECOMMENDED** → investigation immédiate par l'administrateur système dans les 24h.
- Compte admin créé sans autorisation → suspension immédiate + investigation forensique (ausearch -k useradd).
- Tentative de falsification de journal détectée par auditd → incident de sécurité déclaré, isolation du serveur si nécessaire.
- IP bannies > 100 en 7 jours → examen manuel de /var/log/fail2ban.log et /var/log/auth.log.

7. Contrôles techniques garantissant l'intégrité de l'examen

**Accès aux journaux d'administration** : Mode 640 (root:adm) — seul le processus propriétaire peut écrire. SSH par clé ED25519 uniquement (PasswordAuthentication no). Répertoire /var/log/audit/ en 750 root:adm, inaccessible à l'application web. Toute tentative de modification des journaux déclenche une alerte auditd immédiate.

Responsable politique

**BantuDelice — Équipe technique**

Date d'entrée en vigueur

2026-06-03

Prochaine révision

2026-12-03 (semestrielle)

Référence Meta

journal d'audit-22.f.ii